

Guide de recette completSIGEP

Procédure pour tester les fonctionnalités du backend, de l'administration web et de l'application mobile enseignant.

Version du document : 1.3 — 13 septembre 2026 Périmètre : sigep-backend + SigepMobile Type de recette : locale, intégration, sécurité, mobile et préproduction Règle : chaque scénario doit être exécuté avec un résultat attendu vérifié et une preuve conservée.

Document basé sur le code actuel. Le README mobile décrit encore une ancienne application Kotlin/XML ; l'application actuelle est Expo/React Native TypeScript.

Nouveautés de la version 1.1 : l'auto-inscription des enseignants a été supprimée (les scénarios correspondants sont remplacés), l'accès administrateur exige désormais un second facteur par courriel, le format d'emploi du temps s'adapte à chaque établissement, et une console de sécurité est disponible côté plateforme.

Nouveautés de la version 1.2 : six correctifs livrés depuis la version 1.1 ajoutent des scénarios. Import d'emploi du temps : les heures écrites comme heures Excel ne font plus écarter la ligne. Émargement mobile : la séance précédente ne reste plus sélectionnée, et un code étranger est écarté avant la signature. Administration : navigation sans rechargement, suppression d'enseignant refusée proprement, statut Archivé. Second facteur : code de secours tolérant à la saisie, avec un message qui nomme la confusion entre le code et son empreinte.

Nouveautés de la version 1.3 : les quatre limites signalées en 1.2 sont levées et deviennent des scénarios à part entière (ADM-04 à ADM-08). S'y ajoutent deux comportements jusqu'ici absents du guide : la session expirée pendant la navigation, qui doit rendre une vraie page de connexion et non l'insérer dans le cadre d'administration (ADM-09), et la réponse à une adresse inexistante, qui doit être une page d'erreur 404 lisible et non du texte technique (ADM-10).

Sommaire

- Objectif et méthode
- Préparer l'environnement
- Jeu de données de recette
- Tests automatiques
- Authentification et comptes
- Administration web
- Planning et imports
- QR code et émargement en ligne
- Émargement hors-ligne
- Rattrapages
- Statistiques et rapports
- Plans et paiements
- Application mobile
- Sécurité, isolation et résilience
- Préproduction et critères de sortie

1. Objectif et méthode

La recette vérifie que SIGEP permet à un établissement de gérer ses enseignants, son planning et ses émargements, tandis qu'un enseignant consulte ses séances et émerge depuis l'application mobile.

Ordre recommandé : exécuter d'abord les tests automatiques, puis les scénarios avec l'administration web, et enfin les scénarios mobiles. Une grande partie des tests mobiles dépend d'un enseignant validé, d'un planning et d'un QR actif.

Règles de preuve

- Noter la date, l'environnement, le commit testé et le profil Spring actif.
- Pour chaque cas, conserver le résultat HTTP ou une capture d'écran.
- Pour les changements d'état, vérifier la base ou l'écran admin, pas uniquement le message affiché.
- Pour les erreurs attendues, vérifier le code HTTP, le message et l'absence d'écriture indésirable.
- Ne jamais utiliser de vrais secrets, numéros de paiement ou données personnelles en recette.

États de sortie

État	Signification
PASS	Résultat observé conforme et preuve conservée.
FAIL	Résultat différent du résultat attendu, avec reproduction possible.
BLOCKED	Test impossible à exécuter à cause d'un prérequis indisponible.
NOT APPLICABLE	Fonction désactivée volontairement dans l'environnement, justification obligatoire.

2. Préparer l'environnement

2.1 Backend local

Prérequis : JDK 21, Docker Desktop, PostgreSQL local ou Docker, et un terminal PowerShell.

```
cd C:\Users\hp\sigep-backend docker compose up -d .\mvnw.cmd test .\mvnw.cmd spring-boot:run
```

Le plugin Maven active le profil dev lors de spring-boot:run. Vérifier les URLs :

Contrôle	Résultat attendu
GET http://localhost:8080/actuator/health	Réponse JSON avec état UP.
http://localhost:8080/admin-login	Page de connexion administrateur.
http://localhost:8080/swagger-ui.html	Swagger accessible après authentification admin, si activé.

2.2 Variables utiles

En dev, utiliser les valeurs prévues par application-dev.yml. En prod ou préproduction, définir explicitement :

- SPRING_PROFILES_ACTIVE=prod
- DB_URL, DB_USERNAME, DB_PASSWORD
- JWT_SECRET et JWT_QR_SECRET, base64, au moins 32 octets, différentes

■ APP_SECURITY_REQUIRE_HTTPS=true

■ QR_DISPLAY_KEY ou QR_DISPLAY_ALLOWED_IPS

■ APP_SECURITY_ADMIN_OTP_ENABLED — second facteur administrateur, actif par défaut. false le coupe sans redéploiement.

■ APP_SECURITY_ADMIN_OTP_RECOVERY_HASH — empreinte SHA-256 du code de secours. Sans elle, aucun code de secours n'existe.

■ APP_SECURITY_JOURNAL_RETENTION_JOURS — conservation du journal de sécurité, 60 jours par défaut.

Avant toute recette en préproduction : définir l'empreinte du code de secours et conserver le code en clair hors du serveur. Le second facteur dépend d'un courriel ; sans ce filet, une panne d'envoi ferme l'accès à l'administration — y compris pour réparer l'envoi.

2.3 Application mobile

```
cd C:\Users\hp\SigepMobile npm install npm run start
```

Pour tester Android avec le backend local, vérifier la configuration réseau et l'URL utilisée par src/api/apiClient.ts. La valeur actuelle pointe vers https://sigep.store/ ; un test local nécessite donc une configuration adaptée au build ou à l'émulateur.

Attention : l'émulateur Android utilise généralement 10.0.2.2 pour joindre le PC hôte. Un téléphone physique doit utiliser l'IP LAN du PC, avec le pare-feu configuré.

3. Jeu de données de recette

3.1 Comptes et rôles

Compte	Rôle	Usage
Super administrateur	ROLE_SUPER_ADMIN	Onboarding des établissements, plateforme et abonnements.
Administrateur établissement	ROLE_ADMIN	Enseignants, planning, émargements, rapports et paramètres.
Enseignant validé	ROLE_ENSEIGNANT	Application mobile et API enseignant.
Enseignant en attente	PENDING	Vérifier le refus de connexion. Ce cas ne se produit plus qu'après un import sans colonne EMAIL : l'enseignant existe à l'annuaire mais n'a aucun compte.
Enseignant refusé	REJECTED	Vérifier le refus permanent et le message métier.

3.2 Données métier

■ Deux établissements distincts, A et B, actifs.

■ Deux administrateurs, un par établissement.

■ Un enseignant validé, un en attente et un refusé dans A.

■ Un enseignant validé dans B.

■ Deux matières, deux classes, deux salles.

■ Des séances aujourd'hui : passée, en cours, future, déjà émargée et non émargée.

■ Une séance dans le passé récent pour le test hors-ligne.

■ Un fichier planning CSV et un fichier XLSX valides, puis des fichiers invalides.

3.3 QR kiosque

Créer ou récupérer la clé kiosque de l'établissement A dans l'administration. Tester ensuite l'URL universelle :

```
https://<hote>/api/qr/display?etab=<slug-A>&key=<kiosk-key-A>
```

Le QR doit se renouveler automatiquement. Ne pas exposer cette URL dans un document public.

4. Tests automatiques

4.1 Backend

```
cd C:\Users\hp\sigep-backend .\mvnw.cmd test .\mvnw.cmd clean verify
```

Famille	Contrôles attendus
Authentification	Login valide, mauvais mot de passe, 401 sans token, enseignant pending/rejected/validated, refresh et révocation.
Émargement	QR valide, QR invalide, absence de token, persistance et changement de statut.
Rattrapage	Création, acceptation, refus et création de séance.
Rapports	Génération, téléchargement, droits admin et limites de plan.
Paielements	Montant, statut accepté, idempotence et fournisseur injoignable.
Sécurité	Rate limiting, isolation tenant, clés JWT faibles et endpoints protégés.
Import de planning	Heures écrites comme heures Excel, cellules date+heure, types mêlés dans un même fichier : aucune ligne écartée en silence.
Chaînes de sécurité web	Chaque URL d'administration est servie par la chaîne qui lit la session, et non par la chaîne API stateless.

Sur ces deux dernières familles : elles couvrent des défauts qui étaient passés entre les mailles parce que les tests existants ne les exerçaient pas. Les tests de chaîne de sécurité n'utilisent délibérément pas `@WithMockUser` : cette annotation pose le contexte d'authentification en dehors de la chaîne, si bien qu'une requête paraît authentifiée quelle que soit la chaîne qui la sert — et le défaut cherché devient invisible. Ils reproduisent donc ce qu'un navigateur porte réellement : un cookie de session, rien d'autre.

Résultat attendu : aucune régression, build vert et rapport JaCoCo généré après verify.

4.2 TypeScript mobile

Le projet mobile ne possède pas de script de test ou de typecheck dédié. Exécuter au minimum :

```
cd C:\Users\hp\SigepMobile npx tsc --noEmit npx expo start
```

Si tsc révèle des erreurs existantes, les distinguer des erreurs introduites par la version testée et les consigner.

5. Authentification et comptes

AUTH-01 — Login administrateur et second facteurOuvrir /admin-login, saisir les identifiants admin. Attendu : redirection vers /admin-otp, et non vers le dashboard, avec un code à 6 chiffres reçu par courriel. Saisir le code : redirection vers le dashboard pour un administrateur d'établissement, vers /plateforme pour un super administrateur.

AUTH-02 — Aucun accès sans second facteurAprès la saisie du mot de passe, tenter d'atteindre directement /admin/dashboard ou /plateforme sans avoir validé le code. Attendu : redirection systématique vers /admin-otp. Aucune page d'administration ne doit se rendre.

AUTH-03 — L'auto-inscription n'existe plusAppeler POST /api/auth/register. Attendu : la route n'est plus servie. Vérifier également qu'aucun écran d'inscription n'est atteignable depuis l'application mobile, ni aucun lien depuis l'écran de connexion.

AUTH-04 — Compte enseignant créé par l'administrationCréer un enseignant depuis /admin/enseignants/nouveau : aucun champ mot de passe n'est proposé. Attendu : l'enseignant reçoit un courriel contenant un mot de passe provisoire, son statut est VALIDATED et il peut se connecter immédiatement, sans validation supplémentaire.

AUTH-04b — Remplacement forcé du mot de passe provisoireSe connecter sur mobile avec le mot de passe reçu. Attendu : un rappel non masquable s'affiche à l'accueil et le formulaire de sécurité du Profil est déjà ouvert. Changer le mot de passe : la session se referme et le rappel disparaît à la reconnexion.

AUTH-04c — Renvoi des accèsDepuis la liste des enseignants, utiliser « renvoyer les accès ». Attendu : un nouveau mot de passe provisoire est envoyé, l'ancien cesse de fonctionner, et le remplacement est de nouveau exigé.

AUTH-05 — Pending et rejectedTester un compte pending puis rejected. Attendu : HTTP 403, message explicite, aucun token délivré.

AUTH-06 — Refresh et rotationAppeler POST /api/auth/refresh. Attendu : nouvel access token et nouveau refresh token. Réutiliser l'ancien refresh token : attendu HTTP 401.

AUTH-07 — LogoutSe déconnecter puis réutiliser le refresh token. Attendu : révocation et HTTP 401 au refresh.

AUTH-08 — Changement de mot de passeDepuis Profil, saisir l'ancien mot de passe, un nouveau différent, puis reconnecter. Tester ancien mot de passe faux et nouveau identique. Attendu : succès uniquement dans le premier cas ; tous les refresh tokens sont révoqués après changement.

AUTH-09 — Session mobile expiréeForcer ou attendre l'expiration du JWT, appeler une ressource protégée. Attendu : Axios rafraîchit une seule fois, rejoue la requête, puis purge et revient à l'état déconnecté si le refresh échoue.

AUTH-10 — Code de vérification erronéSaisir un code faux. Attendu : message d'erreur, aucun accès ouvert. Répéter cinq fois : le compteur se verrouille et même le bon code ne passe plus — il faut se reconnecter pour repartir de zéro.

AUTH-11 — Code expiréAttendre plus de 5 minutes puis saisir le code reçu. Attendu : refus, aucun accès ouvert.

AUTH-12 — Renvoi d'un codeUtiliser « Je n'ai rien reçu — renvoyer un code ». Attendu : un nouveau courriel arrive et le code précédent est annulé. Répéter : le quatrième renvoi d'une même session est refusé.

Précondition des cas AUTH-13 : la tolérance à la casse et aux séparateurs suppose que APP_SECURITY_ADMIN_OTP_RECOVERY_HASH contienne l'empreinte de la forme canonique du code — majuscules, sans tiret ni espace. Une empreinte calculée sur la chaîne exacte telle qu'elle est imprimée reste acceptée par compatibilité, mais seule une saisie strictement identique passera alors : c'est la configuration, et non un défaut, qui expliquera un refus. La valeur est lue au démarrage ; toute modification exige un redémarrage du serveur.

AUTH-13 — Code de secours : ouverture et tolérance de saisieChoisir un code au format 5 groupes de 4 caractères, par exemple A7K2-9QMR-4XTZ-8WVN-3HCD, et calculer l'empreinte SHA-256 de sa forme canonique — majuscules, sans tiret ni espace : (Get-FileHash -InputStream ([IO.MemoryStream]::new([Text.Encoding]::UTF8.GetBytes("A7K29QMR4XTZ8WVN3HCD")))) -Algorithm SHA256).Hash.ToLower(). Placer le résultat dans APP_SECURITY_ADMIN_OTP_RECOVERY_HASH, redémarrer, se connecter sur /admin-login, puis déplier « Utiliser mon code de secours » sur /admin-otp. Saisir successivement, en repartant d'une session neuve à chaque fois car une ouverture réussie referme cette page : le code tel qu'il est imprimé, le même tout en minuscules, les tirets remplacés par des espaces, le code collé sans aucun séparateur, et le code précédé et suivi d'espaces. Attendu : les cinq formes ouvrent l'accès, sans que le code à 6 chiffres reçu par courriel ait été utilisé. Vérifier ensuite qu'un code dont un seul caractère a été changé reste refusé, et qu'une saisie composée uniquement d'espaces n'ouvre rien ; répéter le refus jusqu'à cinq fois : le quota se verrouille et même le bon code de secours ne passe plus tant qu'on ne s'est pas reconnecté.

Où vérifier la trace d'une ouverture par code de secours : la console de sécurité est réservée au super administrateur. Un administrateur d'établissement qui exécute AUTH-13 ne verra rien et ouvrirait une anomalie à tort. Se connecter avec un compte super administrateur et ouvrir /plateforme/securite : la ligne attendue porte le libellé « Code de secours utilisé » — et non la chaîne technique OTP_CODE_SECOURS, qu'il est inutile de chercher à l'écran.

AUTH-13b — L'empreinte saisie à la place du code est nomméeSur une session neuve, avec l'empreinte configurée comme en AUTH-13, déplier « Utiliser mon code de secours » et coller dans le champ la valeur installée dans

APP_SECURITY_ADMIN_OTP_RECOVERY_HASH — c'est-à-dire l'empreinte, et non le code. Attendu : aucun accès n'est ouvert, et le message indique que la valeur saisie est l'empreinte installée sur le serveur et non le code de secours, en rappelant que celui-ci se présente en 5 groupes de 4 caractères séparés par des tirets. Recommencer en collant la même empreinte en majuscules : le même message doit apparaître. Saisir ensuite une suite quelconque de 64 caractères hexadécimaux qui n'est pas l'empreinte de ce serveur, par exemple soixante-quatre fois la lettre a : le refus indique cette fois que la valeur a la forme d'une empreinte et non celle d'un code de secours. Saisir enfin un code manifestement faux, par exemple 000000 : le message générique « Code invalide ou expiré. » doit réapparaître inchangé.

AUTH-13c — Empreinte absente, entourée de guillemets, ou après un échec

Vider APP_SECURITY_ADMIN_OTP_RECOVERY_HASH ou la retirer de la configuration, redémarrer, puis ouvrir /admin-otp et déplier « Utiliser mon code de secours ». Attendu : aucun champ de saisie n'est proposé ; à sa place, un texte indique qu'aucun code de secours n'est configuré sur ce serveur et nomme la variable attendue. Réinstaller ensuite la même empreinte qu'en AUTH-13, mais entourée de guillemets doubles et suivie d'un espace — la forme que produit couramment un copier-coller dans l'interface d'un hébergeur — puis redémarrer. Attendu : le formulaire réapparaît et le code de secours ouvre l'accès exactement comme en AUTH-13. Empreinte toujours configurée, vérifier enfin que l'information ne se perd pas en cours de navigation : saisir un code à 6 chiffres faux, puis, sur la page renvoyée, cliquer « Je n'ai rien reçu — renvoyer un code ». Sur chacune de ces deux pages, la section de secours doit toujours proposer le champ de saisie, et jamais le message d'absence de configuration.

AUTH-14 — Interrupteur du second facteur Positionner APP_SECURITY_ADMIN_OTP_ENABLED=false et redémarrer. Attendu : la connexion administrateur mène directement à l'espace, sans page de vérification. Remettre true ensuite.

6. Administration web

6.1 Gestion de l'établissement

- Modifier le nom, le slug, le fuseau et les tolérances.
- Vérifier qu'un tenant inactif ne peut plus utiliser ses accès.
- Régénérer la clé kiosque et vérifier que l'ancienne URL QR est refusée.
- Depuis la console de sécurité plateforme, renouveler la clé d'écran de cet établissement et constater le même effet.
- Vérifier l'affichage cohérent du nom et de la marque dans les pages publiques.

6.2 Enseignants et annuaire

- Créer un enseignant avec matricule, nom, prénom, département, grade et courriel — aucun mot de passe n'est demandé, il est généré et envoyé.
- Vérifier que le compte créé est VALIDATED et permet la connexion sans étape supplémentaire.
- Utiliser « renvoyer les accès » et vérifier que l'ancien mot de passe ne fonctionne plus.
- Modifier le statut pending, validated, rejected.
- Importer un annuaire avec la colonne EMAIL : les comptes sont créés et les accès envoyés.
- Importer un annuaire sans colonne EMAIL (fichier historique) : accepté, mais les enseignants restent en PENDING sans compte — c'est le compte « sans e-mail » du rapport d'import.
- Tester doublon de matricule, adresse déjà rattachée à un compte, colonne absente, date ou ligne mal formée.
- Vérifier qu'un administrateur de A ne voit ni ne modifie les enseignants de B.

6.2.1 Départ d'un enseignant : supprimer ou archiver

Précondition : ces scénarios supposent un enseignant qui a réellement servi — au moins une séance émargée et un rapport PDF généré à son nom — car c'est cet historique qui provoquait l'erreur 500. Ils supposent aussi une base à jour des migrations : le statut Archivé s'appuie sur une migration qui étend la contrainte de statut en base, et une base restaurée d'un export

antérieur refuserait l'archivage. Les comptes administrateurs n'ont pas de profil enseignant et ne sont concernés par aucun de ces contrôles.

ENS-01 — Suppression refusée quand l'enseignant laisse un historiquePrendre un enseignant qui a réellement servi : au moins une séance émargée et un rapport PDF généré à son nom (voir RAP-01). Dans /admin/enseignants, cliquer sur l'icône de corbeille de sa ligne et confirmer. Attendu : retour sur la liste avec un message d'erreur qui nomme et dénombre ce qui bloque — séances, émargements, rapports, demandes de rattrapage — et oriente vers l'archivage ; aucune page d'erreur 500. Vérifier ensuite que rien n'a bougé : l'enseignant figure toujours dans la liste et son rapport reste téléchargeable. Refaire l'essai sur un enseignant qui n'a qu'une demande de rattrapage à son nom : le refus doit être identique.

ENS-02 — Suppression toujours possible quand rien ne dépend de l'enseignantCas négatif, à ne pas omettre : le correctif refuse de détruire un historique, il ne doit pas empêcher de supprimer un doublon ou un compte créé par erreur. Créer un enseignant avec son courriel, sans lui affecter la moindre séance, puis le supprimer depuis la liste. Attendu : message de succès indiquant que l'enseignant et son compte de connexion ont été supprimés ; il disparaît de la liste ; la connexion avec ses identifiants provisoires échoue ; son matricule et son adresse redeviennent disponibles pour une nouvelle création.

ENS-03 — Archivage : accès coupé, liste allégée, historique intactSur l'enseignant d'ENS-01, choisir Archiver dans le sélecteur de statut de sa ligne, puis appliquer. Attendu : un message confirme la mise à jour et la ligne quitte immédiatement la liste — c'est le comportement normal, l'archivé étant masqué par défaut. Cocher « Voir les archivés » pour le faire revenir : il porte alors le badge Archivé, et la pagination conserve ce choix. Sa connexion mobile est ensuite refusée avec un message qui dit archivé et non refusé. Vérifier enfin qu'archiver n'efface rien : émargements, statistiques et rapport PDF sont inchangés, et GET /api/enseignants sans paramètre statut continue de renvoyer l'enseignant archivé — statut=ARCHIVE sert à ne lister que les archivés.

Ce que l'archivage ne fait pas : une session mobile déjà ouverte n'est pas interrompue à la seconde. Son rafraîchissement est bien refusé, mais par révocation du jeton — la réponse est un 401 « Session expirée, veuillez vous reconnecter. », et non un message parlant d'archivage. Le contrôle de statut au rafraîchissement est une seconde ceinture, non observable depuis le téléphone. Pour couper immédiatement toutes les sessions d'un établissement, utiliser l'action dédiée de la console de sécurité (cas SEC-04).

6.3 Navigation et droits

Action	Admin	Enseignant	Super admin
Dashboard établissement	Oui	Non	Selon espace plateforme
Gestion enseignants/planning	Oui	Non	Selon périmètre
API personnelle mobile	Selon endpoint	Oui	Non par défaut
Gestion établissements clients	Non	Non	Oui
Actuator metrics/Swagger	Oui	Non	Selon rôle

6.4 Navigation instantanée

Périmètre et préconditions : la navigation instantanée ne s'applique qu'aux adresses commençant par /admin/ et /plateforme ; le reste du site navigue comme avant. Prévoir une liste d'enseignants naturellement plus haute que l'écran, faute de quoi rien ne permet de constater la conservation du défilement. Restent volontairement des navigations classiques : téléchargements, envois de fichiers, liens externes et clics avec Ctrl, Cmd, Maj ou Alt. Exécuter ADM-03 en dernier, il demande de couper la liaison avec le serveur — la rétablir avant de poursuivre la recette.

ADM-01 — La position de lecture n'est plus perdueOuvrir /admin/enseignants avec assez d'enseignants pour que la liste dépasse la hauteur de l'écran. Défiler jusqu'à la dernière ligne, y choisir un statut dans le menu déroulant, puis cliquer sur la coche de validation. Attendu : la page n'est pas rechargée — ni écran blanc, ni indicateur de chargement de l'onglet : c'est le seul critère fiable, la fine ligne de progression pouvant passer inaperçue sur un serveur local — la vue reste sur la ligne travaillée, au décalage près du bandeau de message qui s'ajoute en tête du contenu, le statut affiché est le nouveau, et l'adresse reste /admin/enseignants. Sans remonter, cliquer sur Statistiques dans le dock. Attendu : le contenu change, la vue repart en haut, l'icône active du dock se déplace, le titre de l'onglet suit, et l'adresse devient /admin/statistiques. Utiliser alors le bouton Précédent du navigateur. Attendu : la liste des enseignants revient à la position quittée, pas en haut. Terminer par deux téléchargements : le modèle d'emploi du temps depuis /admin/referentiels, puis un rapport PDF depuis /admin/rapports. Attendu : les fichiers sont réellement enregistrés et la page affichée ne change pas.

ADM-02 — Une page atteinte sans rechargement doit rester aussi utilisable qu'après F5C'est le cas le plus révélateur : remplacer le contenu d'une page n'exécute pas les scripts qu'elle apporte, si bien qu'une page peut arriver visuellement

complète et rester inerte. Depuis /admin/enseignants, rejoindre le tableau de bord par le dock, sans passer par la barre d'adresse. Attendu : les graphiques (tendance d'émargement, profil de la semaine, classement) sont dessinés, exactement comme lorsqu'on ouvre directement /admin/dashboard ; des cadres restés vides que seule la touche F5 remplit constituent une anomalie. Rejoindre de la même façon /admin/abonnement et manipuler le calculateur de total, puis /admin/rapports et déclencher le bouton de synthèse. Attendu : ces commandes répondent comme après un rechargement complet. Rejoindre enfin Nouvel enseignant depuis la liste, saisir un nom, cliquer hors du champ puis attendre une minute sans enregistrer. Attendu : la saisie est intacte, l'actualisation automatique ne s'appliquant pas aux formulaires ; en revanche, de retour sur la liste, une modification faite depuis une autre fenêtre y apparaît toute seule en quelques secondes.

ADM-03 — Action interrompue : la page se recharge, l'action ne se rejoue pas Sur /admin/enseignants, repérer un enseignant disposant d'un compte et ouvrir la boîte de réception de test. Couper la liaison avec le serveur : arrêter le backend, ou passer le navigateur en mode hors connexion. Cliquer sur « renvoyer les accès » et confirmer. Attendu : le navigateur affiche sa page d'erreur de connexion pour l'adresse de la liste, /admin/enseignants, et non pour l'adresse de l'action ; aucune demande de nouvelle soumission du formulaire n'apparaît. Rétablir la liaison et recharger la liste. Attendu : la page s'affiche normalement, et la boîte de test contient au plus un message d'accès pour cette tentative — en général aucun, la requête n'étant jamais partie — jamais deux. C'est l'enjeu du cas : sur un formulaire, un repli qui re-soumettrait au lieu de recharger produirait une seconde exécution de l'action, donc une double suppression sur les boutons destructeurs.

Les limites signalées en version 1.2 sont levées. La palette se referme, les pages arrivent vivantes, les filtres sont conservés, et le rechargement complet ne subsiste que là où il est voulu. Les cas ADM-04 à ADM-08 ci-dessous les vérifient une à une : les exécuter en plus d'ADM-01 à ADM-03, et cette fois sur une liste filtrée, puisque c'est précisément ce qui échouait.

ADM-04 — Une page rejointe sans rechargement répond aux commandes Depuis /admin/enseignants, rejoindre /admin/abonnement par le dock et manipuler le calculateur de total ; puis rejoindre /admin/rapports et déclencher le bouton de synthèse ; puis /admin/dashboard et vérifier que les trois graphiques sont dessinés. Attendu : tout répond comme après un rechargement complet. Reprendre l'essai dans l'autre sens — arriver d'abord directement sur /admin/enseignants par l'adresse, sans passer par le tableau de bord, puis y aller par le dock : c'est le cas qui échouait, la bibliothèque de graphiques n'étant alors pas encore chargée. Les cadres doivent être remplis dès la première arrivée, et non seulement au second passage.

ADM-05 — Ce qu'une page met en route s'arrête quand on la quitte Ouvrir les outils de développement du navigateur, onglet Réseau. Rester sur /admin/dashboard : une requête vers les statistiques part toutes les cinq secondes. Aller sur /admin/enseignants, revenir au tableau de bord, répéter cet aller-retour cinq fois, puis observer le rythme des requêtes. Attendu : toujours une requête toutes les cinq secondes, et non cinq ou dix. Basculer ensuite le thème clair/sombre : l'interface ne doit pas marquer de temps d'arrêt. Même contrôle sur /plateforme.

ADM-06 — Le suivi d'un paiement ne poursuit plus l'administrateur Lancer un paiement Mobile Money jusqu'à la page d'attente, puis, sans attendre la confirmation, rejoindre une autre page de l'administration par le dock. Attendu : la page où l'on travaille n'est jamais rechargée d'elle-même, et aucune requête de suivi du paiement ne continue en arrière-plan.

ADM-07 — La liste revient telle qu'on l'avait laissée Rechercher un enseignant par son nom, choisir un département, aller en page 2 ou 3. Sur une ligne, appliquer un changement de statut. Attendu : on revient sur la même liste, filtrée et à la même page. Recommencer avec le bouton de renvoi des accès, puis avec la corbeille sur un enseignant qui a un historique : le refus conseille d'archiver, et l'enseignant doit être encore là, sous les yeux, pour qu'on puisse le faire. Vérifier enfin que le message d'erreur reste lisible plus de quelques secondes.

ADM-08 — Archiver le dernier résultat d'une recherche Rechercher un nom ne donnant qu'un seul résultat, et archiver cet enseignant. Attendu : la liste s'affiche vide pour cette recherche, sans aucune pastille de pagination, et aucune erreur du serveur. Refaire l'essai sur une recherche donnant onze résultats : aller en page 2, archiver l'unique enseignant qui s'y trouve. Attendu : on est ramené sur la page 1, qui contient bien les dix autres — et non sur une page vide annonçant qu'aucun enseignant n'a été trouvé.

ADM-09 — Session expirée pendant la navigation Ouvrir /admin/enseignants, puis laisser l'onglet de côté assez longtemps pour que la session expire (ou vider le cookie de session depuis les outils du navigateur). Revenir et cliquer une entrée du dock. Attendu : le navigateur affiche une vraie page de connexion, seule à l'écran. Un formulaire de connexion apparaissant à l'intérieur du cadre d'administration — dock toujours visible, en-tête de l'établissement encore affiché — est une anomalie. Même contrôle depuis /plateforme.

ADM-10 — Une adresse qui n'existe pas Saisir dans la barre d'adresse une adresse inexistante, par exemple /page-inexistante. Attendu : une page d'erreur lisible, avec le code 404, et un bouton « Accueil » qui mène à l'accueil du site — et non du texte technique brut, ni une page de connexion. Vérifier au passage, dans les outils du navigateur, que la réponse porte bien le code 404 : c'est lui qui permet aux moteurs de recherche de retirer les adresses supprimées.

7. Planning et imports

PLAN-01 — Création manuelle Créer matière, classe, salle, enseignant puis une séance. Attendu : séance visible dans l'admin et dans le planning mobile du bon enseignant.

PLAN-02 — Import admin CSV Importer un fichier séparé par ; avec DATE;HEURE_DEBUT;HEURE_FIN;MATRICULE;MATIERE;CLASSE;SALLE. Attendu : toutes les lignes valides sont créées et le total est affiché.

PLAN-03 — Import XLSX Répéter en XLSX. Attendu : mêmes résultats métier que le CSV.

PLAN-04 — Import personnel mobile Dans Planning, choisir un fichier via le sélecteur et lancer l'import. Attendu : l'import est rattaché à l'enseignant connecté, sans pouvoir créer une séance pour un autre enseignant.

PLAN-05 — Fichiers invalides Tester fichier vide, extension non supportée, colonnes manquantes, matière inconnue, salle inconnue, matricule inconnu, date invalide, heure de fin avant heure de début et fichier trop volumineux. Attendu : erreur lisible et transaction sans données partielles non prévues.

PLAN-07 — Format d'emploi du temps de l'établissement Dans /admin/referentiels, basculer le format entre STANDARD, UNIVERSITAIRE et SECONDAIRE, puis télécharger le modèle. Attendu : les en-têtes suivent le vocabulaire choisi — unité d'enseignement, niveau/groupe et amphithéâtre en universitaire ; discipline et classe/niveau en secondaire. L'ordre des colonnes ne change jamais, et le modèle comporte bien les 7 colonnes de l'import admin, matricule compris.

PLAN-08 — Cloisonnement du format Changer le format dans A et vérifier que celui de B est inchangé.

PLAN-06 — Consultation mobile Vérifier aujourd'hui, semaine, à émarger, dates et statuts A_FAIRE, EMARGE, EN_RETARD, EN_ATTENTE_VALIDATION.

7.1 Heures écrites comme des heures dans le tableur

Précondition des cas PLAN-09 à PLAN-11 : le défaut corrigé ne se reproduit que si les cellules d'horaire sont de vraies heures pour le tableur. Une colonne mise au format Texte, ou une valeur préfixée d'une apostrophe, produit du texte et masque précisément le cas à tester : vérifier que le contenu s'aligne à droite et que le format de cellule est bien h:mm. Par ailleurs, l'application mobile n'annonce qu'un nombre de séances importées ; le détail des lignes écartées ne figure que dans la réponse HTTP, sous lignesEnErreur et erreurs. Ne pas conclure sur le seul message affiché par le mobile.

PLAN-09 — Heures écrites comme des heures Préparer un classeur .xlsx à six colonnes, dans l'ordre DATE | HEURE_DEBUT | HEURE_FIN | MATIERE | CLASSE | SALLE, en-tête sur la première ligne. Y saisir trois lignes portant toutes la même date, par exemple 07/09/2026, et saisir les horaires directement dans les cellules : 08:00 et 10:00, 12:30 et 13:00, 16:00 et 17:00. Ne pas les préfixer d'une apostrophe et ne pas mettre les colonnes au format Texte. Compléter matière, classe et salle. Importer depuis l'application mobile, écran Mon Profil, bouton « Importer un fichier Excel / CSV », ou par POST /api/import/mon-planning avec le fichier en paramètre multipart file. Attendu : totalImporte à 3, lignesEnErreur à 0, liste erreurs vide. Appeler ensuite GET /api/seances/date/2026-09-07 : le nombre de séances relues doit égaler le nombre de lignes du fichier, chacune avec ses horaires exacts. C'est ce comptage qui distingue la version corrigée de l'ancienne : le défaut ne décalait pas les dates, il faisait disparaître les lignes dont les heures étaient de vraies heures, et seules survivaient les lignes saisies en texte — d'où l'illusion de jours arbitraires.

PLAN-10 — Cellule portant à la fois une date et une heure Dans un second classeur au même format, saisir une valeur contenant date et heure dans les trois premières colonnes : 07/09/2026 09:45 en DATE, 07/09/2026 09:45 en HEURE_DEBUT, 07/09/2026 11:45 en HEURE_FIN. Compléter matière, classe et salle, puis importer par la même voie que PLAN-09. Attendu : lignesEnErreur vaut 0, totalImporte vaut 1, et la séance relue est datée du 07/09/2026 et va de 09:45 à 11:45. Ni la date ni l'heure ne doit être perdue : une séance datée du 31/12/1899, une heure ramenée à 00:00 ou une ligne écartée constituent un échec.

PLAN-11 — Écritures tolérées et refus toujours signalé Contrôle de non-régression. Construire un fichier dont les heures sont du texte et y répartir les écritures tolérées : 08:00, 8:00, 08h00, 08h, 08, en gardant à chaque ligne une heure de fin postérieure à l'heure de début. Varier de même les dates : 07/09/2026, 7/9/2026, 2026-09-07, 07-09-2026. Ajouter une dernière ligne délibérément fautive, heure de début 25:00. Importer, puis refaire l'essai en CSV séparé par ;, et en import administrateur par POST /api/admin/import/planning — sept colonnes, le matricule étant intercalé en quatrième position : DATE | HEURE_DEBUT | HEURE_FIN | MATRICULE_ENSEIGNANT | MATIERE | CLASSE | SALLE. Attendu : toutes les lignes bien formées sont importées ; la ligne fautive est la seule refusée, lignesEnErreur vaut 1 et erreurs contient une entrée de la forme Ligne N : heure invalide « 25:00 » (attendu HH:mm). Reprendre avec une date illisible : le refus est signalé de la même manière, avec le format

jj/mm/aaaa. Une ligne fautive ne doit ni interrompre l'import ni disparaître du rapport.

Ordre des colonnes de l'import administrateur : aucun contrôle d'en-tête n'existe pour le planning, contrairement à l'import d'annuaire. Un fichier dont le matricule est placé ailleurs qu'en quatrième position n'est donc pas rejeté comme « non conforme » : il produit des séances incohérentes. Vérifier l'ordre avant de conclure à une anomalie de contenu.

8. QR code et émargement en ligne

QR-01 — Affichage kiosque autoriséOuvrir le QR universel avec le slug et la clé de A. Attendu : page HTML, image QR lisible, compte à rebours, renouvellement.

QR-02 — Affichage refuséTester clé absente, clé incorrecte, slug inconnu, établissement inactif et configuration sans clé/IP. Attendu : HTTP 403.

QR-03 — Scan mobile valideAvec une séance du jour dans la fenêtre autorisée, ouvrir Scan, scanner le QR de A, signer puis confirmer. Attendu : émargement créé, séance EMARGE, historique mis à jour.

QR-04 — QR expiré ou forgéScanner un QR expiré, modifié, issu d'une autre clé ou d'un mauvais type. Attendu : refus métier, aucune écriture.

QR-05 — Mauvais établissementUn enseignant de A scanne le QR de B. Attendu : refus et aucune modification de séance.

QR-06 — HoraireTester avant la tolérance, pendant la séance, après la fin dans la tolérance, puis après la tolérance. Attendu : succès ou retard selon la règle, puis refus hors fenêtre.

QR-07 — Double émargementSoumettre deux fois la même séance. Attendu : une seule ligne d'émargement et seconde demande refusée.

QR-08 — Signature manuscriteAprès un QR valide, la fenêtre de signature s'ouvre. Attendu : le bouton Valider reste inactif tant que rien n'est tracé ; « Effacer » remet le cadre à blanc ; « Annuler » revient au scan sans rien enregistrer. Après validation, ouvrir le rapport PDF de l'enseignant : le tracé doit y figurer. Côté API, tester aussi une signature au format base64 invalide ou trop volumineuse : validation rejetée, aucune écriture.

QR-09 — Séance d'un autre établissementTenter d'émarger une séance rattachée à un autre établissement que celui de l'enseignant. Attendu : refus, et un évènement critique SEANCE_AUTRE_ETABLISSEMENT dans la console de sécurité.

QR-10 — Réarmement du scannerÉmarger une séance, revenir à l'accueil, puis rouvrir l'onglet Scan. Attendu : la caméra se rouvre immédiatement et aucune animation de succès du scan précédent ne subsiste. Enchaîner un second émargement sur une autre séance.

Préconditions des cas QR-11 à QR-13 : disposer d'un enseignant dont la journée compte au moins trois séances encore à émarger, toutes dans la fenêtre horaire autorisée, et ouvrir l'écran de scan par le bouton central « Émarger » de la barre du bas. Passer par une carte de séance de l'accueil ou du planning transmet la séance en paramètre : la liste de sélection ne s'affiche alors pas, la liste n'est pas rechargée, et le cas ne teste plus la même chose. Rappel : le contrôle de forme ajouté sur le téléphone n'est pas une vérification de sécurité — signature, expiration, anti-rejeu et appartenance à l'établissement restent jugés par le serveur, et les cas QR-04, QR-05 et QR-06 gardent toute leur valeur.

QR-11 — Aucune séance ne reste sélectionnée après un émargementOuvrir l'écran de scan par le bouton central Émarger, avec au moins trois séances du jour encore à émarger. La liste « Sélectionnez votre séance : » s'affiche. Choisir la première séance : son bouton se distingue visuellement des autres. Scanner le QR affiché en salle, signer, valider ; le résumé de succès apparaît, puis l'application revient d'elle-même à l'accueil. Rouvrir l'écran par le même bouton. Attendu : la séance qui vient d'être émarginée a disparu de la liste, et aucun bouton n'est mis en évidence — plus aucune séance n'est présélectionnée. Choisir alors une autre séance, attendre que le QR affiché en salle se soit renouvelé, puis le scanner : l'émargement est accepté pour cette séance.

Piège de QR-11 : ne pas rescanner l'image du QR précédent. Tant que l'écran de salle n'a pas tourné, c'est le même jeton, que le serveur refuse comme déjà utilisé. Or ce refus et celui d'une séance déjà émarginée s'affichent sur le téléphone avec exactement le même texte — « Vous avez déjà émarginé pour cette séance ». Un second scan trop rapide fait donc ouvrir une anomalie sur un refus parfaitement normal, et ne prouve rien sur le défaut corrigé.

QR-12 — Code étranger écarté avant la fenêtre de signatureSur l'écran de scan, sélectionner d'abord une séance. Scanner ensuite un code qui n'est pas un QR SIGEP : étiquette d'un produit, QR d'une carte de visite, ou QR fabriqué à partir d'un simple

texte ou d'une URL. Attendu : le cadre passe au rouge avec une croix et une vibration d'erreur, et le statut affiche « Ce n'est pas un QR SIGEP — scannez l'écran de la salle ». La fenêtre de signature ne s'ouvre pas et aucune requête d'émargement n'est envoyée : le vérifier dans les journaux du serveur et constater dans l'administration que la séance garde son statut d'origine. Environ une seconde plus tard la caméra se rouvre, et le scan du vrai QR de salle aboutit normalement. Répéter enfin le scan du code étranger sans avoir sélectionné de séance : le message affiché reste celui du code étranger, l'alerte de sélection requise n'apparaît pas.

QR-13 — Cas négatif : aucun QR légitime écarté par le téléphone Ce cas est le plus important des trois : il vérifie que le contrôle de forme ne refuse rien que le serveur aurait accepté. Un client plus sévère que le serveur refuserait des QR valables, hors de portée de tout diagnostic côté serveur. a) Scanner le QR de la page kiosque de son propre établissement (cas QR-01) : la fenêtre de signature s'ouvre et l'émargement aboutit. b) Attendre le renouvellement du QR affiché, puis scanner le code renouvelé : même comportement. c) Couper le réseau du téléphone et scanner un QR de salle valide : la fenêtre de signature s'ouvre encore, la signature est recueillie et l'émargement part en file hors-ligne (section 9). d) Faire scanner par un enseignant de A le QR de l'établissement B (cas QR-05) : le téléphone laisse passer, la fenêtre de signature s'ouvre, et le refus n'arrive qu'après l'envoi, prononcé par le serveur. Attendu : dans ces quatre situations, aucun refus n'est prononcé par le téléphone lui-même ; le message « Ce n'est pas un QR SIGEP » ne doit jamais apparaître.

9. Émargement hors-ligne

Précondition : utiliser une version mobile récente. Le backend exige désormais qrToken dans la file hors-ligne ; les anciennes entrées sans QR sont purgées lors de la synchronisation.

- Charger une séance du jour encore à émarger.
- Scanner le QR pendant la fenêtre autorisée.
- Couper le réseau du téléphone.
- Signer et confirmer l'émargement.
- Vérifier le compteur de file hors-ligne.
- Rétablir le réseau et déclencher le rafraîchissement ou la synchronisation.
- Dans l'admin, vérifier que l'émargement est en attente.

Cas	Résultat attendu
Synchronisation valide	Entrée retirée de la file, séance EN_ATTENTE_VALIDATION, valide=false.
Admin accepte	Émargement valide, séance EMARGE, comptabilisée dans les statistiques.
Admin refuse	Émargement supprimé, séance A_FAIRE.
QR absent	Entrée purgée, présence non prouvable.
QR d'un autre tenant	HTTP 400 métier, entrée supprimée comme erreur définitive.
Réseau indisponible pendant sync	Entrée conservée pour réessai ultérieur.
Séance trop ancienne/future	Refus définitif, entrée supprimée.
Plafond mensuel dépassé	Refus définitif avec message de plafond.

10. Rattrapages

RAT-01 — Demande mobile Choisir une séance, une date et heure futures, saisir un motif. Attendu : demande EN_ATTENTE visible dans Mes demandes.

RAT-02 — Validation admin Accepter avec une salle. Attendu : demande ACCEPTE et séance de rattrapage créée.

RAT-03 — Refus admin Refuser. Attendu : demande REFUSE, aucune séance créée.

RAT-04 — Validations Tester date passée, motif vide, séance inexistante, demande déjà traitée et salle inexistante. Attendu : erreurs métier et absence de doublon.

11. Statistiques et rapports

11.1 Statistiques enseignant

- Ouvrir Stats et vérifier total, émargées, non émargées, taux, heures, retards, semaine.
- Comparer le taux avec le nombre de séances réellement émargées.
- Vérifier qu'un émargement hors-ligne en attente n'est pas compté comme validé avant décision admin.
- Vérifier le fuseau horaire configuré pour les séances.

11.2 Dashboard admin

- Vérifier les KPIs enseignants, émargement, rattrapages et heures.
- Vérifier le rafraîchissement des données sans rechargement complet.
- Vérifier les graphiques de tendance, taux par jour et classement.
- Tester l'analyse IA seulement si AI_ENABLED=true et clé configurée ; sinon le repli par règles reste fonctionnel.

11.3 Rapports PDF

RAP-01 Générer les rapports pour une période valide. Télécharger un PDF et vérifier enseignant, période, séances et émargements.

RAP-02 Tester période inversée, rapport inexistant, téléchargement par enseignant et téléchargement groupé hors plan. Attendu : refus approprié.

12. Plans et paiements

Ces tests sont à exécuter en environnement de test fournisseur. Aucun appel réel ne doit être déclenché avec un numéro réel.

Fonction	Scénarios
Inscription SaaS	Établissement valide, champs manquants, doublon, rate limit, validation super admin.
Plans	FREE, PRO, ENTERPRISE, quota enseignants, fonctionnalité avancée interdite puis autorisée.
Stripe	Webhook signature correcte, incorrecte, événement rejoué, montant/devise incorrects.
Mobile Money générique	Secret absent, secret incorrect, charge utile invalide, référence rejouée.
NovaSend	Initiation, numéro invalide, opérateur inconnu, OTP, succès, refus, statut inconnu, API indisponible, expiration et arbitrage.

Critère critique : un paiement ne doit prolonger un abonnement qu'après vérification serveur du statut fournisseur, avec montant et devise conformes. Toute notification répétée doit rester idempotente.

13. Application mobile

13.1 Navigation et présentation

- Lancer l'app : splash puis écran Login sans écran blanc.
- Vérifier clavier, scroll et affichage sur petit écran.
- Vérifier Login, Home, Planning, Scan, Stats, Profil et Rattrapage. L'écran Register n'existe plus et aucun lien ne doit y mener.
- Vérifier qu'aucun contenu ne passe sous la barre d'état ou l'encoche, en particulier la barre des jours du Planning.
- Depuis Rattrapage, vérifier la présence d'un bouton de retour : cet écran n'a pas de barre d'onglets.
- Vérifier les transitions, états de chargement, erreurs et boutons désactivés.
- Tester rotation si supportée, reprise après arrière-plan et relance de l'application.

13.1.1 Ouverture de l'application

Avant ces essais : la couleur de démarrage est fixée dans la configuration de l'application ; elle n'est effective que sur un paquet construit après le correctif. Par ailleurs, un rechargement à chaud sur une application déjà lancée ne rejoue pas l'ouverture : il faut à chaque fois fermer complètement l'application, puis la relancer.

MOB-01 — L'ouverture joue le scan de la marqueFermer complètement l'application (la retirer des applications récentes) puis la relancer, et regarder l'écran sans y toucher. Attendu : les quatre coins d'un cadre de visée se referment sur le logo, un faisceau lumineux le balaie de haut en bas et l'éclaire à son passage, deux cercles s'ouvrent autour du logo puis s'effacent — ils restent contenus dans la zone de visée et n'en sortent pas —, les lettres S I G E P se lèvent une à une, la mention ÉMARGEMENT ACADÉMIQUE apparaît sous le nom, et une barre de progression se remplit en bas de l'écran. L'ensemble dure environ quatre à cinq secondes puis laisse la place à l'écran suivant, sans aucune action du testeur.

Reconnaître l'ancienne version : ne pas se fier à l'immobilité du logo — l'ancienne ouverture le faisait aussi apparaître par un fondu avec effet de ressort. Les repères sûrs sont les deux libellés Système d'Émargement et Portail académique numérique, les trois points qui clignotent en boucle, et une durée totale d'environ une seconde et demie. Si l'un de ces trois repères est présent, le correctif n'est pas embarqué et les cas MOB-01 à MOB-03 sont sans objet.

MOB-02 — Aucune page blanche au démarrageSur un paquet installé construit après ce correctif, forcer l'arrêt de l'application puis la relancer en observant la toute première image affichée. Attendu : l'écran est sombre (bleu nuit) dès la première image, le logo y est nettement visible, et l'enchaînement vers l'animation puis vers l'écran de connexion se fait sans aucun flash blanc ni rupture de couleur. Une page blanche d'apparence vide au démarrage — le logo, clair, y devenant invisible — est le défaut corrigé. Refaire l'essai avec le téléphone réglé en thème clair : le résultat doit être identique, l'application conservant sa présentation sombre et ses textes lisibles.

MOB-03 — Réduction des animations et sortie automatiqueActiver la réduction des animations du téléphone (Android : Accessibilité puis « Supprimer les animations » ; iOS : Accessibilité, Mouvement, « Réduire les animations »), puis fermer et relancer l'application. Attendu : l'ouverture se limite à un fondu — le logo et le cadre sont présents d'emblée, sans faisceau, sans particules en dérive et sans ondes — et l'écran de connexion arrive en un peu plus d'une seconde. Le rail de la barre de progression reste visible dans les deux réglages : ce qui distingue le mode réduit est qu'il ne se remplit pas. Attendu dans les deux réglages : l'ouverture se termine d'elle-même sans toucher l'écran, et l'application enchaîne sur l'écran de connexion, ou directement sur l'accueil si une session valide est encore enregistrée. Une ouverture qui reste figée sur le logo, ou qui exige un appui pour passer, est une anomalie bloquante.

13.2 Home

- Bonjour avec prénom et établissement.
- Prochain cours et compte à rebours.
- Statistiques rapides et progression.
- Pull-to-refresh.
- Badge réseau et compteur d'émargements en attente.
- Synchronisation automatique après retour en ligne.

13.3 Résilience réseau

Situation	Attendu
Backend lent au démarrage	Timeout toléré, message approprié, pas de blocage permanent.
Erreur 401 simultanée sur plusieurs appels	Un seul refresh, les appels attendent puis sont rejoués.
Refresh invalide	Tokens et profil supprimés, callback session expirée, retour Login.
Erreur 4xx pendant sync offline	Entrée retirée comme erreur définitive.
Panne réseau pendant sync	Entrée conservée.

13.4 Profil et session

- Afficher les informations du compte et de l'établissement.
- Sur un compte encore en mot de passe provisoire : rappel visible à l'accueil et formulaire de sécurité ouvert d'office.
- Changer le mot de passe avec succès.
- Vérifier les validations et messages d'erreur.
- Se déconnecter : appel serveur best effort puis purge SecureStore.
- Relancer l'app : session restaurée si tokens présents, sinon Login.

14. Sécurité, isolation et résilience

14.1 Authentification et autorisation

- Chaque endpoint protégé sans Authorization renvoie 401, pas 403.
- Un rôle enseignant ne peut pas atteindre les endpoints admin.
- Un utilisateur ne peut accéder qu'à ses données.
- Un compte désactivé ne peut plus se connecter ni rafraîchir sa session.
- Le changement de mot de passe exige l'ancien mot de passe.
- Aucune page d'administration ne se rend avant validation du second facteur.
- POST /api/profil/mot-de-passe sans jeton renvoie 401 ; l'identité vient du jeton, jamais du corps de la requête.

14.2 Isolation tenant

Créer des données identiques dans A et B puis tenter de les lire ou modifier depuis le mauvais compte. Tester enseignants, séances, émargements, rattrapages, rapports, plans et intentions de paiement. Attendu : aucune fuite ; idéalement 404 pour une ressource étrangère, conformément au contrat.

14.3 Rate limiting

Répéter les endpoints sensibles au-delà des budgets configurés : login, refresh, inscription établissement, POST /api/profil/mot-de-passe (5 par minute et par IP, comme le login), login admin, initiation Mobile Money et appels IA. Attendu : HTTP 429, puis retour à la normale après la fenêtre. Vérifier ensuite que chaque refus apparaît en DEBIT_DEPASSE dans la console de sécurité.

14.4 Secrets et HTTPS

- Démarrage prod sans JWT_SECRET : refus.
- Clé base64 trop courte : refus.
- JWT_SECRET égal à JWT_QR_SECRET : refus.
- Secret de dev utilisé hors profil dev : refus.
- Profil prod sans HTTPS requis : refus.
- En-têtes sécurité et CORS limités aux origines configurées.

14.5 Console de sécurité plateforme

Ouvrir /plateforme/securite en tant que super administrateur.

SEC-01 — Accès réservéTenter la page avec un compte administrateur d'établissement. Attendu : HTTP 403. Ces évènements traversent tous les établissements.

SEC-02 — Les détections remontentProvoquer successivement : un mot de passe admin refusé, un second facteur erroné, un QR d'un autre établissement, un QR rejoué, un dépassement de débit. Attendu : chaque fait apparaît au journal avec sa gravité, son horodatage et sa source.

SEC-03 — Bilan par établissementVérifier que la section « Par établissement » classe bien les établissements par nombre de faits critiques, et que cliquer sur un nom filtre le journal sur lui seul.

SEC-04 — Couper les sessionsDepuis une session mobile active, déclencher l'action sur l'établissement concerné. Attendu : message de confirmation avec le nombre de comptes, et le rafraîchissement du jeton échoue ensuite côté mobile, qui revient à l'écran de connexion.

SEC-05 — Renouveler la clé d'écranAvec un écran kiosque ouvert, déclencher l'action. Attendu : l'ancienne URL cesse de fonctionner et l'écran doit être rouvert depuis l'administration de l'établissement.

SEC-06 — Les remédiations sont consignéesAprès SEC-04 et SEC-05, vérifier qu'un évènement REMEDIATION apparaît, portant l'identifiant du super administrateur qui a agi.

SEC-07 — Aucun secret au journalParcourir les évènements et vérifier qu'aucun mot de passe, jeton, jeton QR ni code à usage unique n'y figure — seulement des adresses, des identifiants et des libellés.

SEC-08 — Le journal ne casse rienLe journal étant un témoin, aucune de ses défaillances ne doit interrompre une requête. Vérifier qu'aucune route ne permet d'effacer une ligne du journal.

SEC-09 — TraficGénérer des requêtes puis consulter la courbe. Attendu : elle réagit. Redémarrer l'application : la courbe repart de zéro, le compteur étant tenu en mémoire — comportement attendu, pas une anomalie.

14.6 Tâches et observabilité

- /actuator/health est disponible pour la sonde.
- Metrics et Prometheus sont protégés.
- Les tâches planifiées ne s'exécutent qu'une fois en multi-instance grâce à ShedLock.
- Les tâches asynchrones conservent le contexte tenant et sécurité puis le nettoient.
- Les erreurs possèdent une référence corrélable dans les logs.

15. Préproduction et critères de sortie

15.1 Smoke test après déploiement

- GET /actuator/health retourne UP.
- Les logs montrent démarrage Spring réussi et migrations Flyway appliquées.
- Login admin et login enseignant fonctionnent.
- Une séance du jour apparaît sur mobile.
- Un QR de kiosque est affiché et renouvelé.
- Un émargement en ligne est comptabilisé.
- Un émargement hors-ligne est synchronisé puis validé par l'admin.
- Une demande de rattrapage est créée puis traitée.
- Un rapport est généré et téléchargé.
- Un webhook de paiement de test est idempotent.

15.2 Critères de sortie

- Aucun test critique en FAIL : auth, tenant, QR, émargement, offline, paiement.
- Tests automatiques backend verts.
- Typecheck mobile sans nouvelle erreur.
- Pas de secret dans les logs, captures ou fichiers de recette.
- Les anomalies bloquantes ont un ticket, un responsable et un plan de correction.
- Le résultat de recette est signé par le responsable technique et le représentant métier.

15.3 Matrice de couverture

Domaine	Critique	Responsable	Preuve
Auth / session	Oui	Backend + mobile	Réponses HTTP + capture
Tenant / droits	Oui	Backend	Test croisé A/B
Planning / import	Oui	Admin	Fichier + compte rendu
QR / émargement	Oui	Admin + enseignant	Historique + base
Offline	Oui	Mobile + admin	Avant/après synchronisation
Rattrapage	Non bloquant métier selon release	Mobile + admin	Statuts
Rapports / stats	Oui	Admin	PDF + chiffres
Paiement	Oui si activé	Plateforme	Événement + abonnement

16. Fiche d'anomalie

Champ	À renseigner
Identifiant	BUG-AAAA-MM-JJ-NNN
Gravité	Bloquante, critique, majeure, mineure
Environnement	Local, préproduction, production ; profil ; version backend/mobile

Champ	À renseigner
Préconditions	Compte, tenant, séance, fichier, configuration
Étapes	Une étape par ligne, reproductibles
Résultat attendu	Contrat fonctionnel ou code HTTP attendu
Résultat observé	Message exact, code, capture, identifiant de log
Impact	Utilisateurs et données concernés
Reproductibilité	Toujours, souvent, intermittent
Correctif vérifié	Version, test de non-régression, date et testeur

Fin de recette : archiver ce PDF complété avec les exports de résultats, les captures, les fichiers d'import de test et la liste des anomalies. Les secrets et données personnelles doivent être retirés avant archivage ou partage.